TrustVault

Owner: Akhil
Reviewer: Shiva
Contributors:
Date Generated: Mon Oct 19 2026

Executive Summary

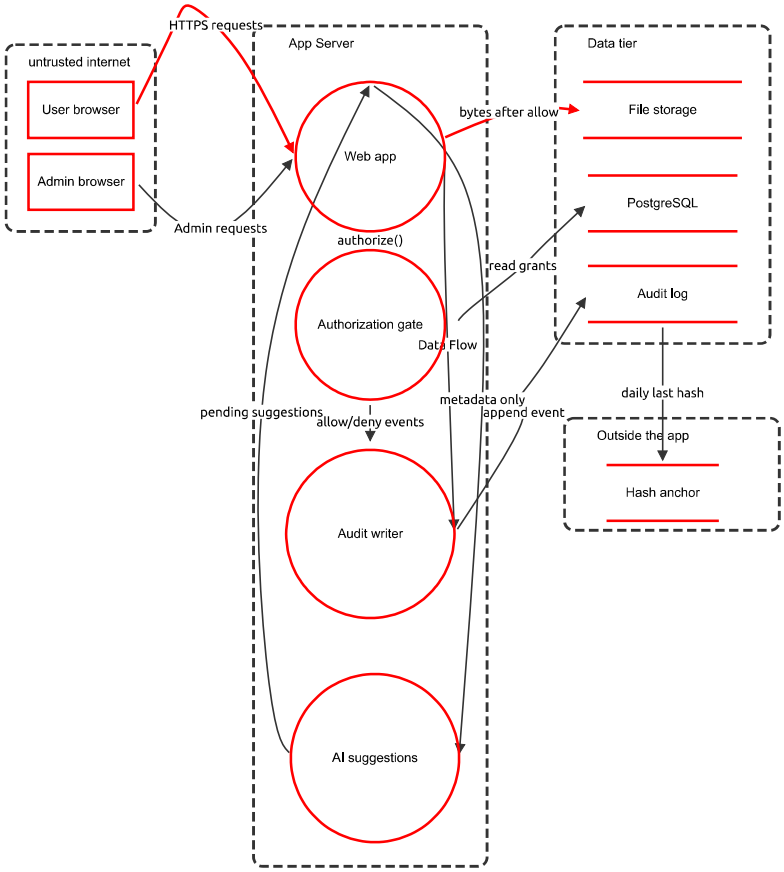
High level system description

Secure document sharing platform with RBAC and append-only audit logging.

Summary

Total Threats	17
Total Mitigated	0
Total Open	17
Open / Critical Severity	1
Open / High Severity	4
Open / Medium Severity	9
Open / Low Severity	0
Open / TBD Severity	3

TrustVault main data flow



TrustVault main data flow

User browser (Actor)

Description: owner or viewer

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	New STRIDE threat	Spoofing	Medium	Open		Brute force, credential stuffing attacks	Implement rate-limiting middleware (e.g., Django Axes) on login endpoints, enforce account lockout policies after failed attempts, and support multi-factor authentication (MFA).

Admin browser (Actor)

Description: Manages users

Number	Title	Type	Severity	Status	Score	Description	Mitigations
14	New STRIDE threat	Spoofing	Medium	Open		weak password, no second factor	every admin action is audited.
15	New STRIDE threat	Repudiation	Medium	Open		Provide a description for this threat	every admin action is audited.

bytes after allow (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
17	New STRIDE threat	Information disclosure	Medium	Open		if the file stream is cached or shared	Provide remediation for this threat or a reason if status is N/A

read grants (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

authorize() (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

allow/deny events (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

append event (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Data Flow (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

metadata only (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

daily last hash (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

pending suggestions (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

HTTPS requests (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
16	New STRIDE threat	Information disclosure	Medium	Open		, if traffic ever runs over plain HTTP.	Provide remediation for this threat or a reason if status is N/A

Admin requests (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Web app (Process)

Description: login, upload, search

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	New STRIDE threat	Spoofing	High	Open		Stolen or reused session after revocation	Enforce short session expiration times, invalidate session tokens upon logout/revocation via a centralized token version column, and set strict secure cookie flags (HttpOnly, Secure, SameSite=Strict).
4	New STRIDE threat	Elevation of privilege	Medium	Open		Mass assignment; admin grants themselves access	Explicitly declare form or serializer fields (fields = [...]) in Django forms/DRF serializers, preventing users from injecting privilege or role fields into POST/PUT payloads.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	New STRIDE threat	Tampering	High	Open		Login floods, huge uploads	Apply granular rate limiting on resource-heavy routes, set explicit request payload size limits at the reverse proxy/Django settings level, and implement IP-based throttling.

Authorization gate (Process)

Description: One decision point

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	New STRIDE threat	Spoofing	TBD	Open		Provide a description for this threat	Provide remediation for this threat or a reason if status is N/A
6	New STRIDE threat	Elevation of privilege	TBD	Open		A route skips the check	Use centralized base view classes or required decorators (@authorize) for all document endpoints, paired with automated unit tests that verify every route explicitly triggers the authorization check.
7	New STRIDE threat	Information disclosure	Critical	Open		403 vs 404 reveals a file exists	Standardize unauthorized responses to return a generic 404 Not Found for both non-existent resources and unauthorized files, preventing resource enumeration.

Audit writer (Process)

Description: logs allow and deny

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	New STRIDE threat	Repudiation	Medium	Open		Document text tricks it into widening access	Treat all AI output strictly as untrusted recommendations; enforce a mandatory human-in-the-loop confirmation step before any suggested access grant can be applied.

AI suggestions (Process)

Description: pending until confirmed

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	New STRIDE threat	Information disclosure	Medium	Open		File contents sent to an outside API	Run language model workflows locally or through isolated, internal-only service containers. Restrict inputs to metadata summaries rather than raw sensitive file bodies.

File storage (Store)

Description: only after allow

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	New STRIDE threat	Information disclosure	TBD	Open		Direct URL or guessed key	Store uploaded files entirely outside the public web root (MEDIA_ROOT unexposed to static hosting) and stream file content exclusively through authenticated Django views backed by the single authorization gate.

PostgreSQL (Store)

Description: Users,grants

Number	Title	Type	Severity	Status	Score	Description	Mitigations
12	New STRIDE threat	Tampering	High	Open		Grants edited directly in the database	Apply least-privilege database user permissions (preventing the Django app connection from running DDL or overriding internal system tables directly), and monitor database activity logs.

Audit log (Store)

Description: Append-only

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	New STRIDE threat	Tampering	High	Open		Row edited or deleted; chain rewritten	Configure PostgreSQL database-level rules or triggers prohibiting UPDATE and DELETE commands on the audit_events table, and maintain row-by-row cryptographic hash chains.

Hash anchor (Store)

Description: Daily last hash

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	New STRIDE threat	Tampering	Medium	Open		Anchor altered or never checked	Store daily hash anchor verification summaries on an external read-only medium or a separate append-only log store where the primary Django application possesses zero write access.